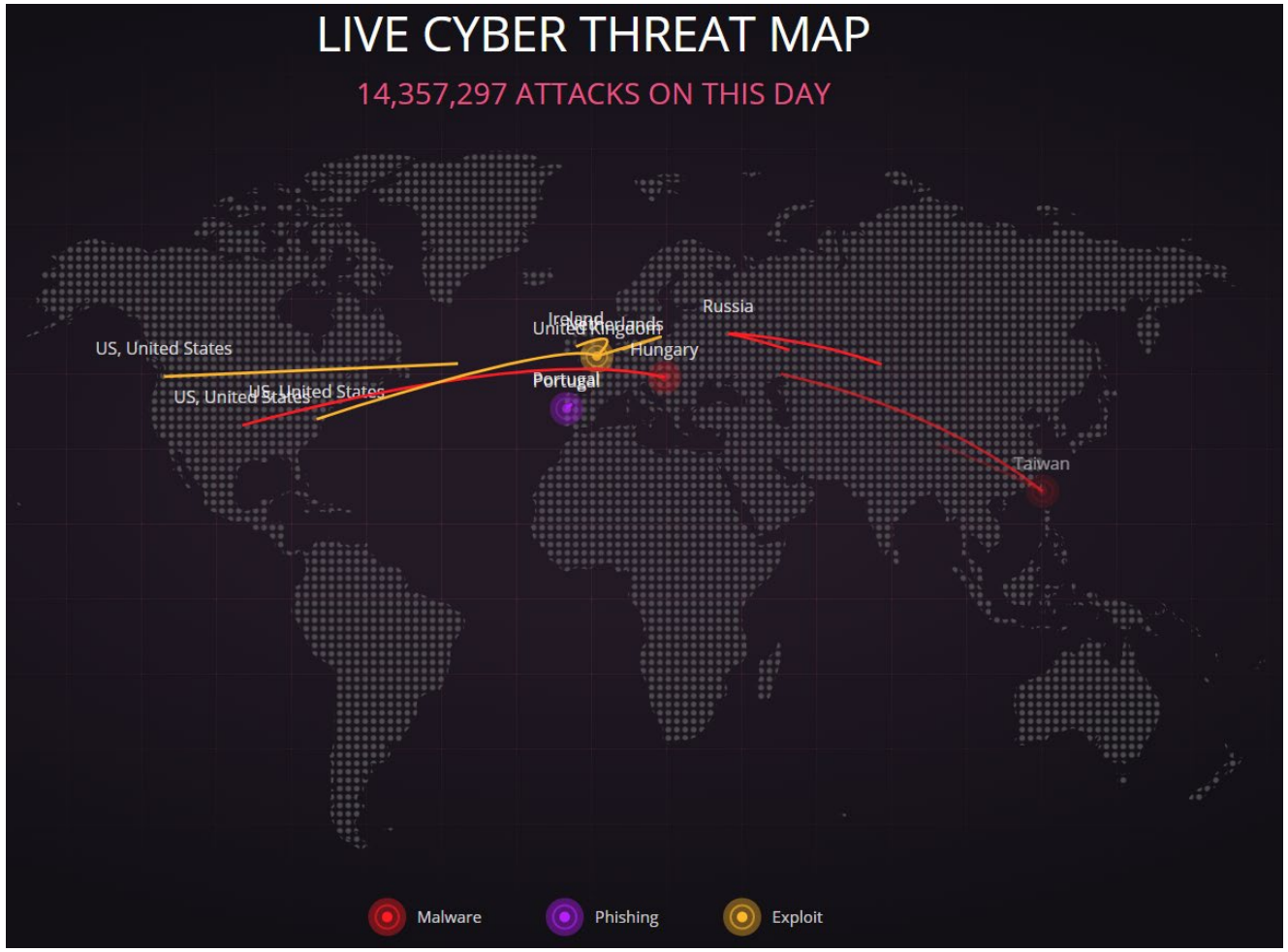
Nätverkssäkerhet och ACL-intro

Planering

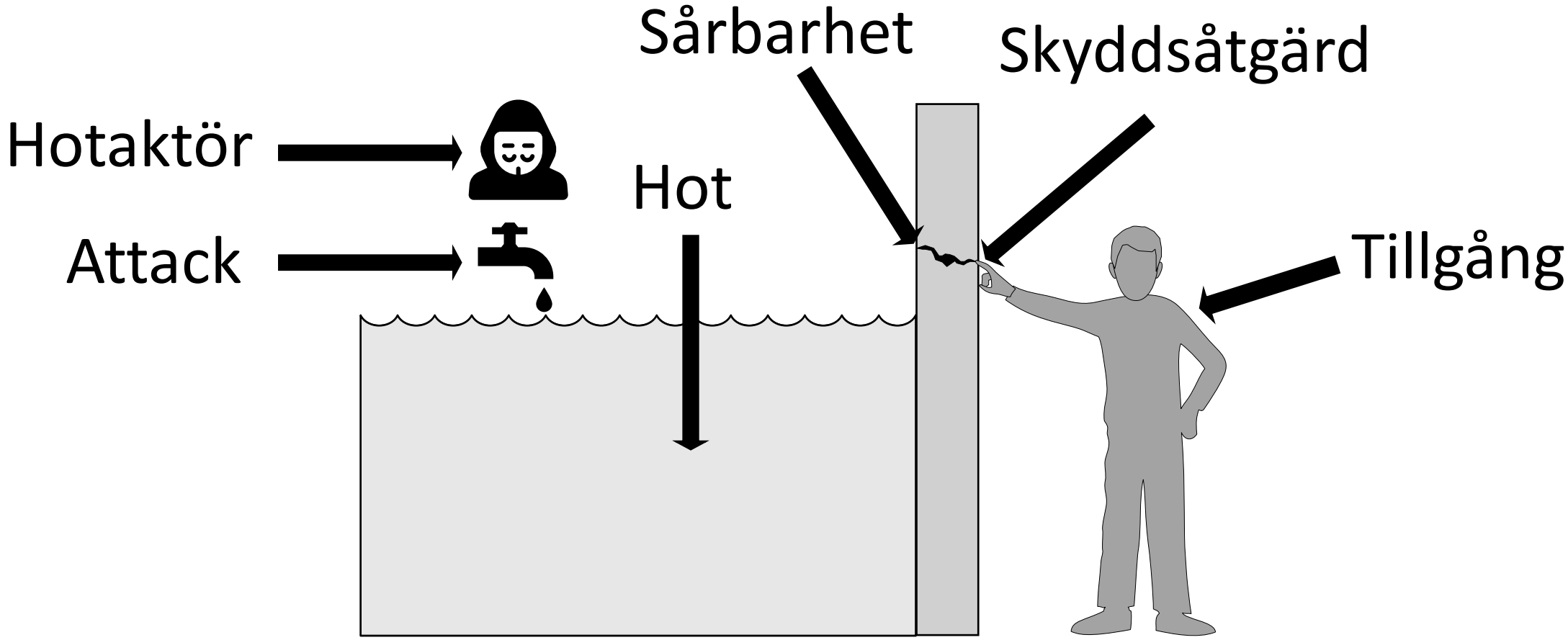
Vecka	Dag	Moment
13	Tis	~~**Kursintro & föreläsning – WAN (7)**~~
	-	~~**Inspelad föreläsning – NAT (6)**~~
	Tor	~~**Laboration & Dugga 1**~~
14	Tis	~~**Inspelad föreläsning – OSPF (1, 2)**~~
	-	~~**Inspelad föreläsning – Multi-Area OSPF**~~
	Tor	~~**Laboration & Dugga 2**~~
15	Ons	**Föreläsning** – Nätverkssäkerhet och ACL-intro (3, 4)
	-	**Inspelad föreläsning** – ACL (4, 5)
	Tor	**Laboration & Dugga 3 (Halvtidsutvärdering)**
16	Tis	**Föreläsning** – BGP (Sigurd)
		Inspelad föreläsning – VPN & IPsec (8)
	Tor	**Laboration**
	Sön	**Deadline Projekt 1**
17	Tis	**Föreläsning** – Enhetshantering & övervakning (10)
	-	**Inspelad föreläsning** – Systematisk felsökning (12)
	Tor	**Laboration & Dugga 4**
18	Tis	**Föreläsning** – Nätverksdesign & PPDIOO (11)
	-	**Inspelad föreläsning** – QoS (9)
	Tor	**Laboration & Dugga 5**
	Fre	**Laboration**
19	Mån	**Föreläsning** – Trender inom nätverk (13-14)
	-	**Inspelad föreläsning** – Genomgång inför praktiskt prov
	Mån/ Tis	**Laboration**
	Sön	**Deadline Projekt 2**
20	Tis	**Föreläsning** – Gästföreläsning Telia (kl. 13.15)
	Tor	**Laboration**
21	Tor	**Laboration**
22	-	**Tentavecka (inkl. praktiskt prov och certifikatstest)**

Nu har vi kopplat upp företaget mot Internet och andra WAN-tjänster, dags att säkra upp nätverket…

Nätverk är ständigt under attack



Riskhantering



Pfleeger, C. P., Pfleeger, S. L., & Coles-Kemp, L. (2024). Security in computing (Fifth edition). Prentice Hall.

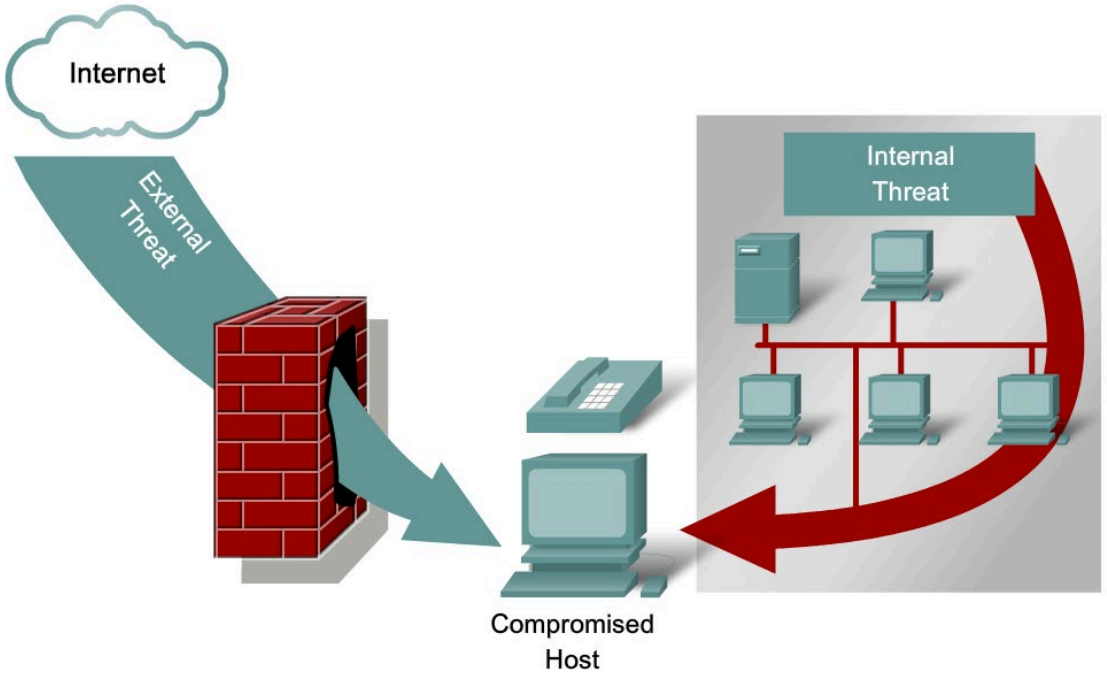
Risk = Hot * Sårbarhet

Sannolikheten att en viss hotfaktor utnyttjar en sårbarhet

Risk = (Hot * Sårbarhet) * Värde(Tillgång) – Åtgärder

Sannolikheten att en viss hotfaktor utnyttjar en sårbarhet i en tillgång, minus de skyddsåtgärder som implementeras

Externa och interna hot



- **Hot från utsidan (externa)**
  - Hackers, malware
  - Andra organisationer (industrispionage)
  - DoS och DDoS
- **Hot från insidan (interna)**
  - Anställda
  - Gäster
  - **Både medvetna och omedvetna handlingar**
- Från ett nätverkssäkerhetsperspektiv måste man skydda båda!
- Interna ”attacker” genererar ofta större skada, och står för den största andelen

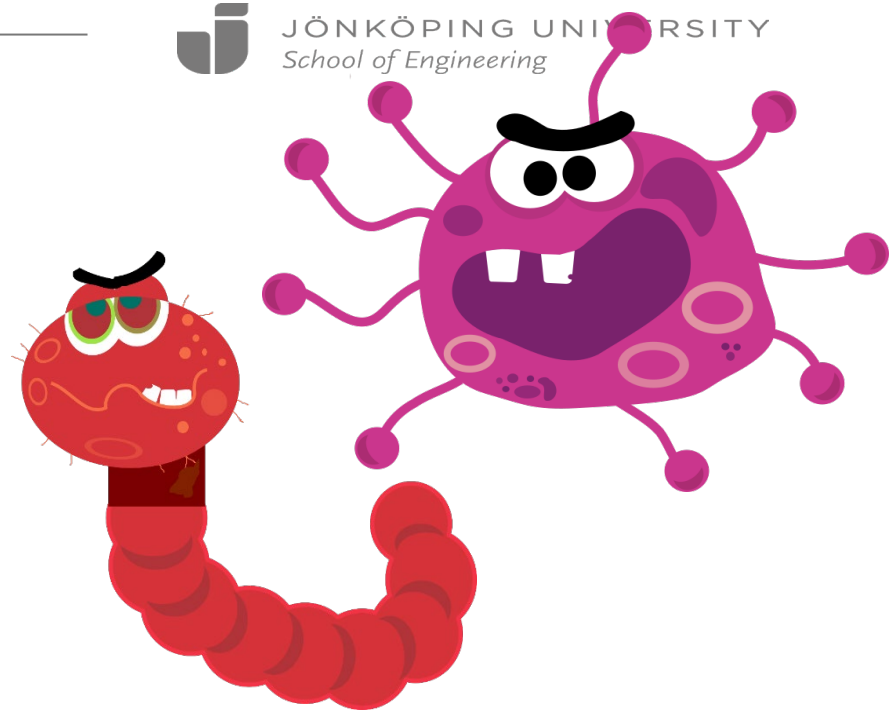
Förlorad data

- I den moderna tiden är information/data ofta viktigare än fysiska resurser
- Förlorad data kan orsakas både medvetet och omedvetet och kan orsaka:
  - Dåligt rykte
  - Minskade marknadsfördelar och kundantal, juridiska tvister
  - Minskad vinst
  - Totalt sett ofta stora finansiella förluster!
- Här används redundans, backup, DLP-tekniker, etc. för att skydda företaget

Hackers och ”hacking”

- Man brukar dela in hackers i olika hattar
- Annan indelning:
  - **Script-kiddies**
  - **Vulnerability brokers**
  - **Hacktivists**
  - **Cyber Criminal**
  - **State-sponsored**
- Nu för tiden krävs allt mindre djup teknisk kunskap
- Vi kommer gå igenom mer i Nätverkssäkerhet och Cybersäkerhet

Malware (skadlig kod)



- **Malware** har tre huvudtyper:
  - **Virus**
  - **Trojanska hästar**
  - **Maskar**
- Finns olika definitioner och beskrivningar. I denna kurs utgår vi från boken förenklade syn, men var medvetna om att andra böcker kan beskriva det annorlunda
- Förutom dessa finns också **annan skadlig kod**
  - **Ransomware**
  - **Spyware**

Your personal files are encrypted!

Private key will be destroyed on

06/03/2022
18:42

Time left
71:59:47

Yout important files **encryption** produced on this computer: photos, videos, documents, etc. Hereis a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key RSA-2048generated for this computer. To decrypt files you need to obtain the **private key**.

The **Single Copy** of the private key, which will allow you to decrypt the files, located on a secret server on the internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

To obtain the private key for this computer, which will automatically decrypt files, you need to pay 300 USD / 300 EUR / similar amount in another currency.

Click <<Next>> to select the method of payment and the currency.

Any attempt to remove or damage this software will lead to the immediate destruction of the private key by server.

NEXT >>

JÖNKÖPING UNIVERSITY

tietoevry

```
C:\>type akira_readme.txt
Hi friends,

Whatever who you are and what your title is if you're reading this it means the internal infrastructure of your company
is fully or partially dead, all your backups - virtual, physical - everything that we managed to reach - are completely
removed. Moreover, we have taken a great amount of your corporate data prior to encryption.

Well, for now let's keep all the tears and resentment to ourselves and try to build a constructive dialogue. We're fully
 aware of what damage we caused by locking your internal sources. At the moment, you have to know:

1. Dealing with us you will save A LOT due to we are not interested in ruining your financially. We will study in depth
your finance, bank & income statements, your savings, investments etc. and present our reasonable demand to you. If you
have an active cyber insurance, let us know and we will guide you how to properly use it. Also, dragging out the negotia
tion process will lead to failing of a deal.
2. Paying us you save your TIME, MONEY, EFFORTS and be back on track within 24 hours approximately. Our decryptor works
properly on any files or systems, so you will be able to check it by requesting a test decryption service from the begin
ning of our conversation. If you decide to recover on your own, keep in mind that you can permanently lose access to som
e files or accidently corrupt them - in this case we won't be able to help.
3. The security report or the exclusive first-hand information that you will receive upon reaching an agreement is of a
great value, since NO full audit of your network will show you the vulnerabilities that we've managed to detect and used
 in order to get into, identify backup solutions and upload your data.
4. As for your data, if we fail to agree, we will try to sell personal information/trade secrets/databases/source codes
- generally speaking, everything that has a value on the darkmarket - to multiple threat actors at ones. Then all of thi
s will be published in our blog -
5. We're more than negotiable and will definitely find the way to settle this quickly and reach an agreement which will
satisfy both of us.

If you're indeed interested in our assistance and the services we provide you can reach out to us following simple instr
uctions:

1. Install TOR Browser to get access to our chat room - https://www.torproject.org/download/.
2. Paste this link -
3. Use this code -                    - to log into our chat.

Keep in mind that the faster you will get in touch, the less damage we cause.
```

https://news.sophos.com/en-us/2023/12/21/akira-again-the-ransomware-that-keeps-on-taking/

https://akiral2iz6a7qgd3ayp3l6yub7xx2uep76idk3u2kollpj5z3z636bad.onion

[AKIRA]

AKIRA

Well, you are here. It means that you're suffering from cyber incident right now. Think of our actions as an unscheduled forced audit of your network for vulnerabilities. Keep in mind that there is a fair price to make it all go away.

Do not rush to assess what is happening - we did it to you. The best thing you can do is to follow our instructions to get back to your daily routine, by cooperating with us you will minimize the damage that might be done.

Those who choose different path will be shamed here publicly. The functionality of this blog is extremely simple - enter the desired command in the input line and enjoy the juiciest information that corporations around the world wanted to stay confidential.

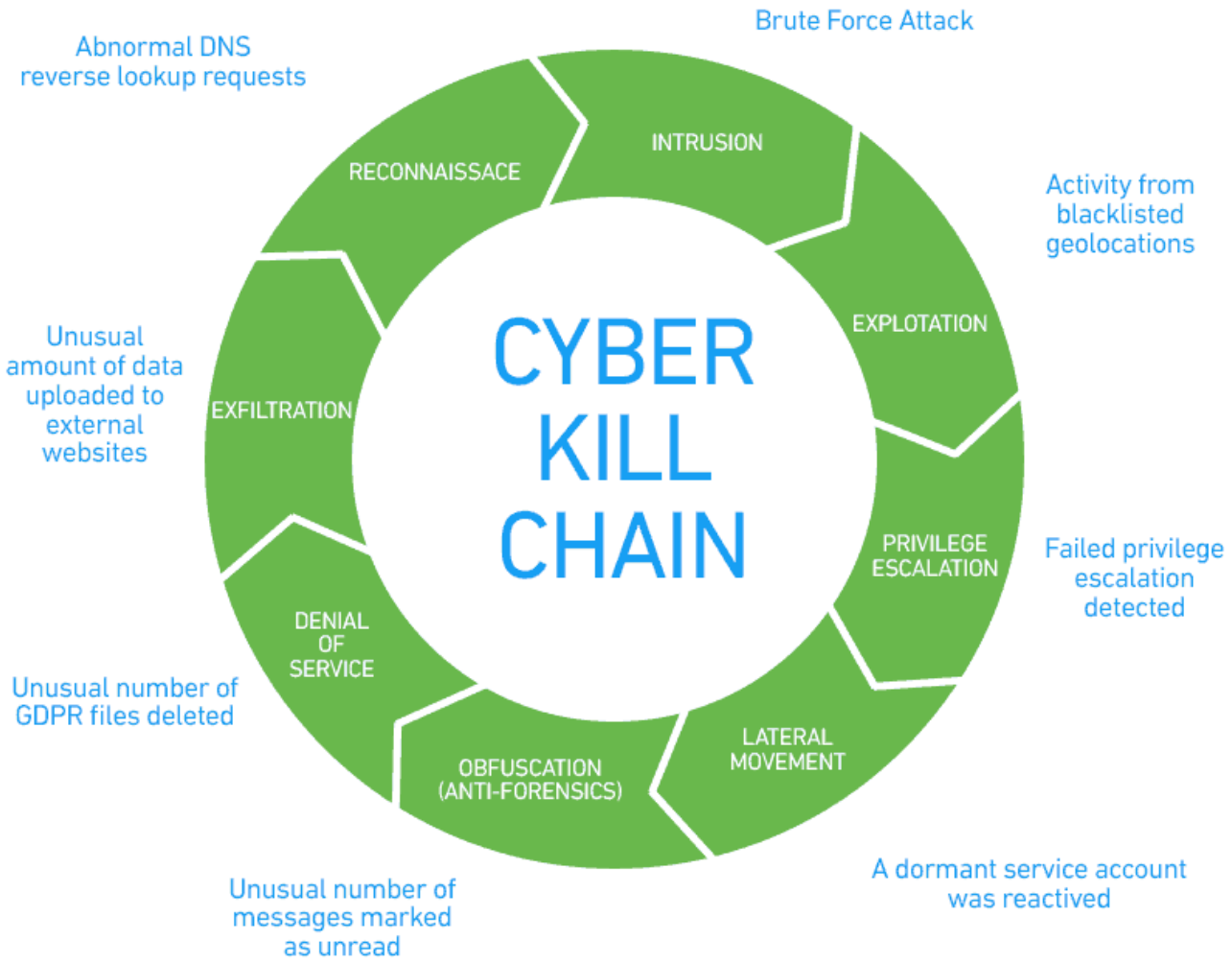
Remember. You are unable to recover without our help. Your data is already gone and cannot be traced to the place of final storage nor deleted by anyone besides us.

```
guest@akira:~$ help

List of all commands:

 leaks      — hacked companies
 news       — news about upcoming data releases
 contact    — send us a message and we will contact you
 help       — available commands
 clear      — clear screen

guest@akira:~$
```

Kategorisering av nätverksattacker

- **Vilka tre kategorier finns det (enligt Cisco)?**
- **Reconnaissance attacks**
  - Samla information om ett nätverk
- **Access attacks**
  - Intrång in till låsta system och konton
  - **Social Engineering**
- **Denial of Service attacks**
  - Överbelastning eller andra metoder för att sänka ett nätverk eller en mjukvara

Cyber Kill Chain



https://www.exabeam.com/explainers/information-security/cyber-kill-chain-understanding-and-mitigating-advanced-threats/

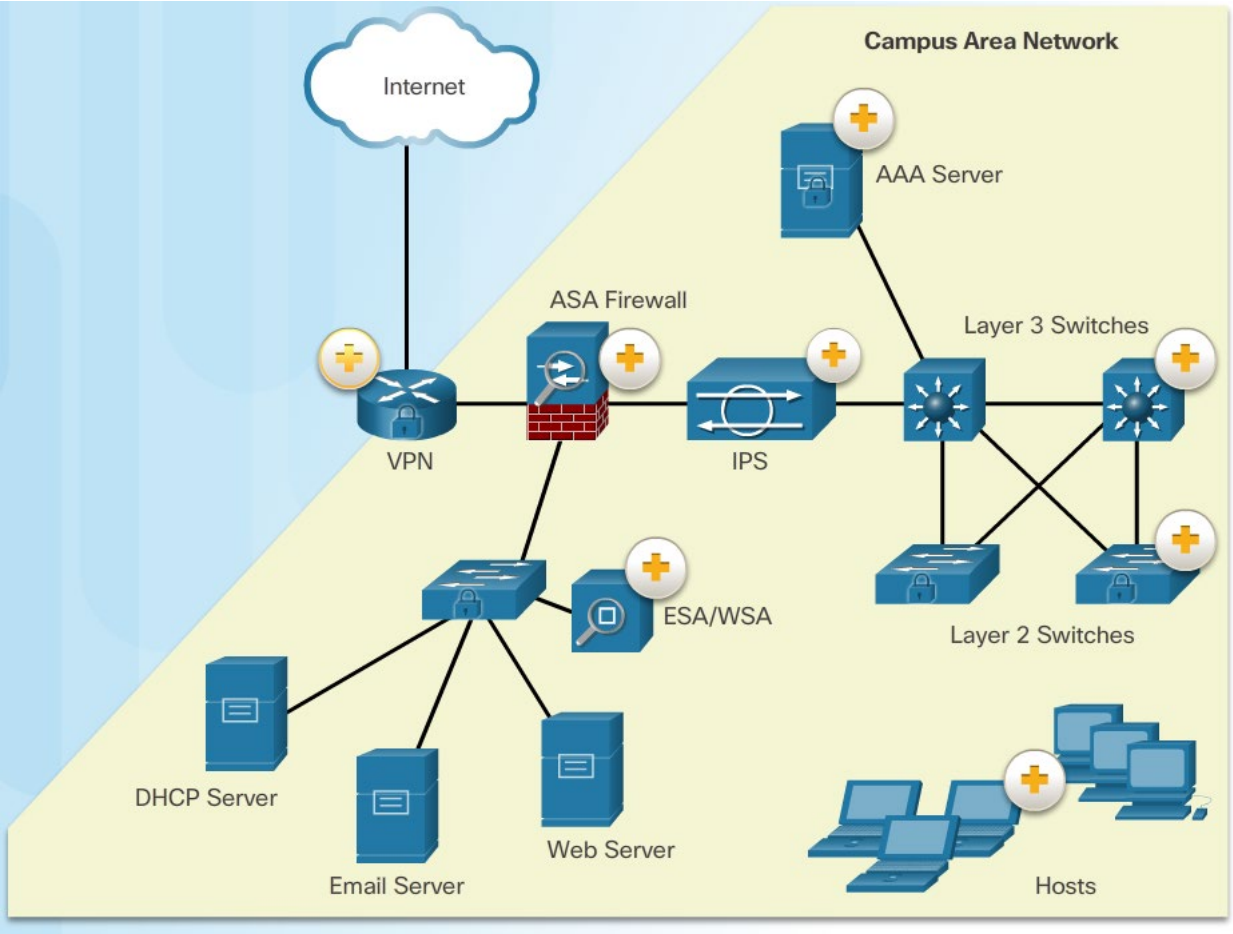
Hur skyddar vi oss?

- CIA är en utav de mest populära principerna när man pratar om **informationssäkerhet**:
  - Confidentiality (Konfidentialitet)
  - Integrity (Riktighet)
  - Availability (Tillgänglighet)
- Vad innebär detta rent praktiskt?

Defense-in-depth

Defense-in-depth

- Skydd på flera olika nivåer
- Brandvägg (Cisco ASA, FortiGate)
- VPN (Virtual Private Network)
- IPS (Intrusion Prevention System)
- ESA / WSA
- AAA



Fördjupningar av säkerhet och säkerhetsåtgärder…

- …kommer i kursen **Nätverkssäkerhet** och **Cybersäkerhet**

- Något vi dock ska utforska vidare idag är:

Access Control Lists (ACL)

Vad är en ACL?

- ACL = Access Control List
- Tillåter eller kastar paket som matchar en regel (paketfiltrering)
  - Filtrering på lager 3 och 4
- Funktioner:
  - Minska viss nätverkstrafik för att öka prestandan i nätverket
  - Skydda exempelvis routinguppdateringar och fjärrkonfiguration
  - Blockera användning av en viss tjänst för en klient
- Fungerar som en enklare brandvägg

Vad kan man filtrera på?

- Source IP
- Destination IP
- Source port
- Destination port
- Protokoll (ICMP, HTTP, FTP osv.)
- TCP state (SYN, ACK, osv.)
- Det finns även mer avancerade ACLer som klarar mer

ACLer använder wildcard-maskar

- Wildcardmasken anger vilka bitar som måste matcha en IP-adress
  - 0 = Match
  - 1 = Inte match
- Exempel:

Router(config)# **access-list 10 permit 192.168.10.0 0.0.0.255**

IP:	192.168.10.0	11000000.10101000.00001010.**00000000**
WC:	0.0.0.255	00000000.00000000.00000000.**11111111**

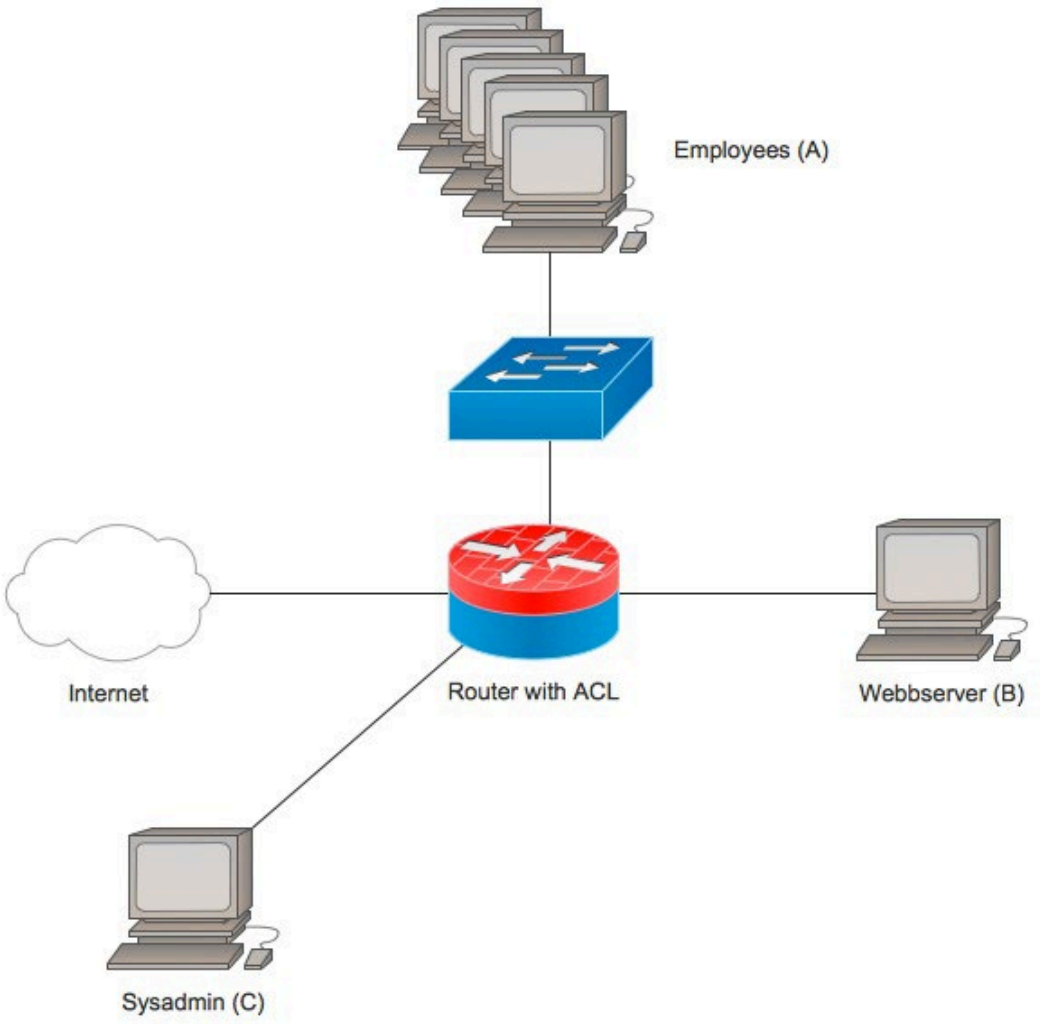
Keywords

Keyword	Funktion
Any	Matchar vilken IP som helst
Host	Efterföljande IP används med /32-mask

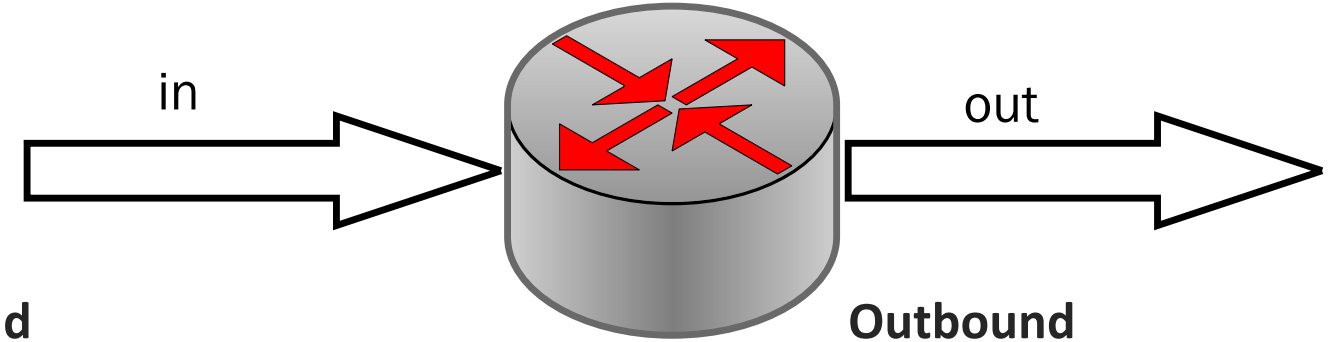
```
R1(config)#access-list 1 permit 0.0.0.0 255.255.255.255
R1(config)#access-list 1 permit any

R1(config)#access-list 1 permit 192.168.10.10 0.0.0.0
R1(config)#access-list 1 permit host 192.168.10.10
```

Hur många ACLer kan man ha?

- ”The three Ps”
  - En per protokoll (IPv4, IPv6, IPX, etc.)
  - En per interface (fa0/0, fa0/1, etc.)
  - En per riktning (in eller ut)



Riktning på ACL

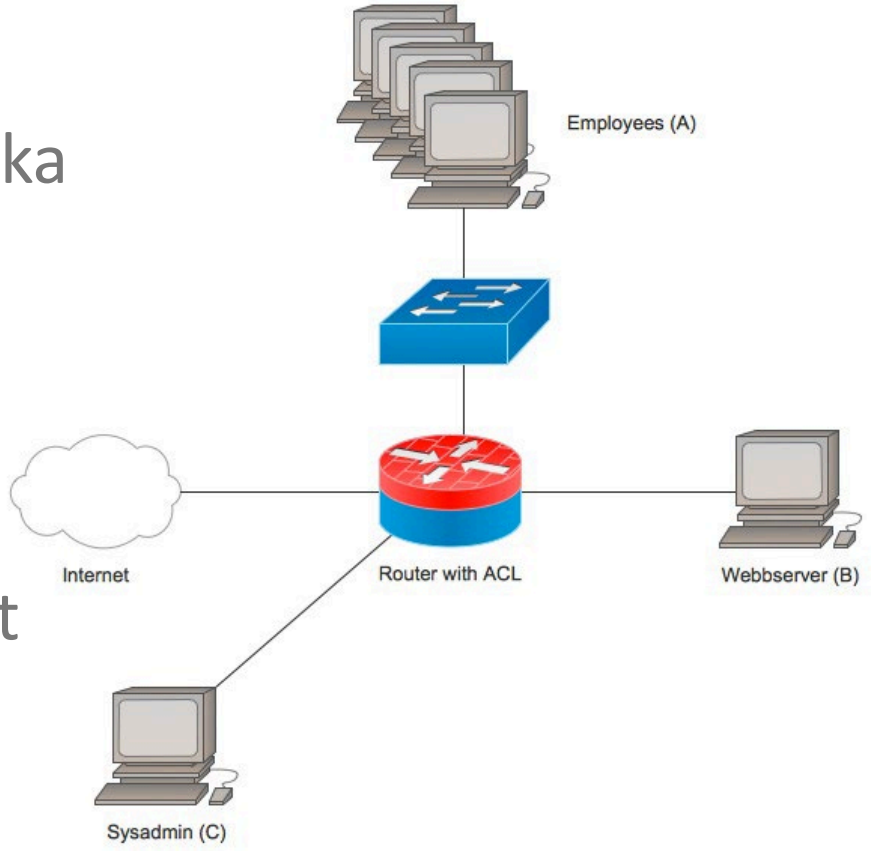


Inbound
Filtrering innan paketet routas

Outbound
Filtrering efter paketet routas

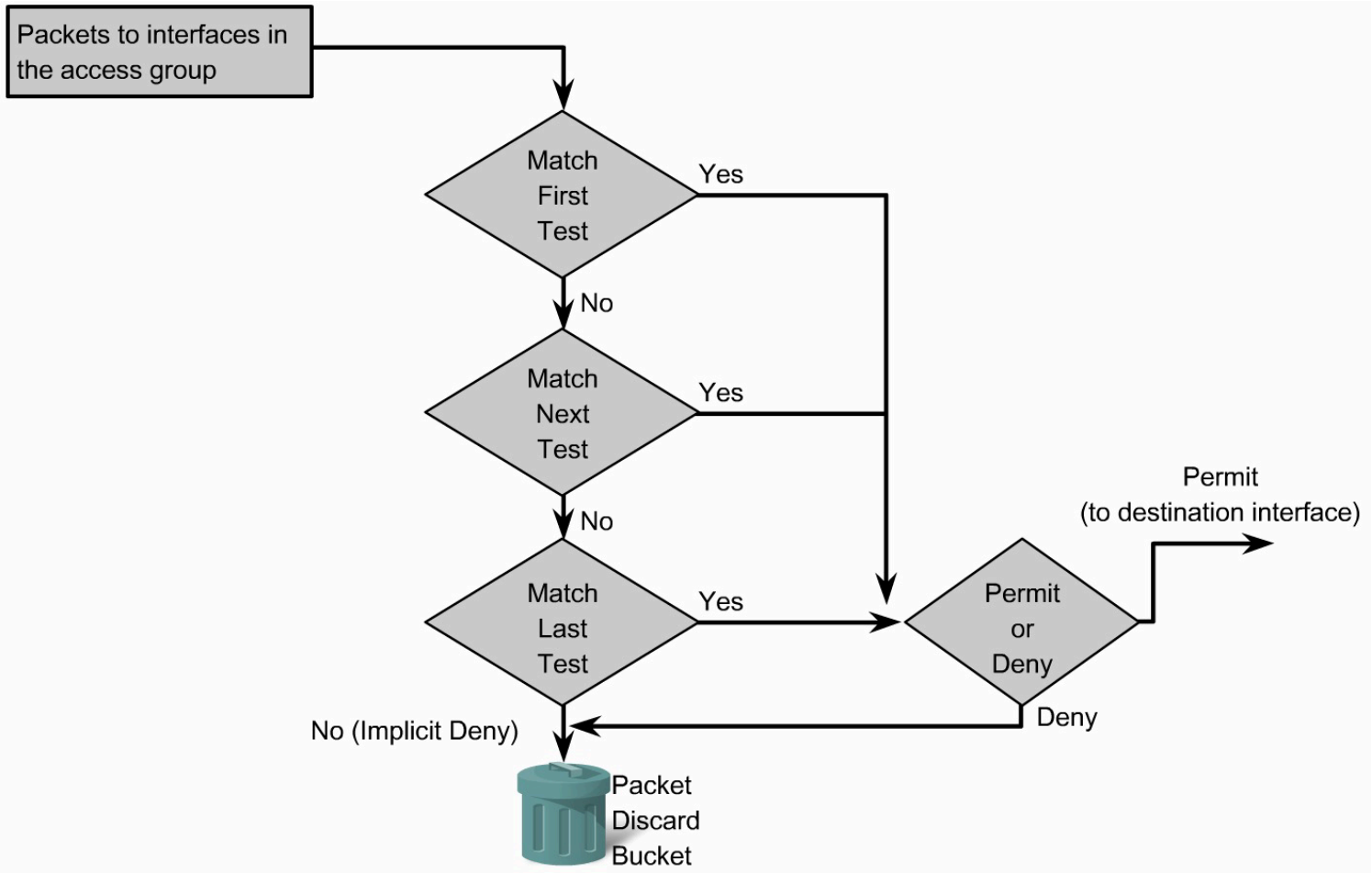
Exempel: ACL

- **Regel 1:** Om ett paket kommer från nät A och ska till IP-adress B, och har destinationsport 80, kan det passera
- **Regel 2:** Om ett paket kommer från IP-adress C ochska till IP-adress B kan det passera oavsett portnummer
- **Regel 3:** All annan trafik till B skall kastas



ACE

- Varje rad i en ACL är en ACE (access control entry)
- Funktion enligt:
  - Kollar en rad i taget
  - Vid en matchning går den ur listan
  - Längst ner finns alltid en **implicit deny**



”Kluring”

- Varför är nedanstående ACL inte optimal?

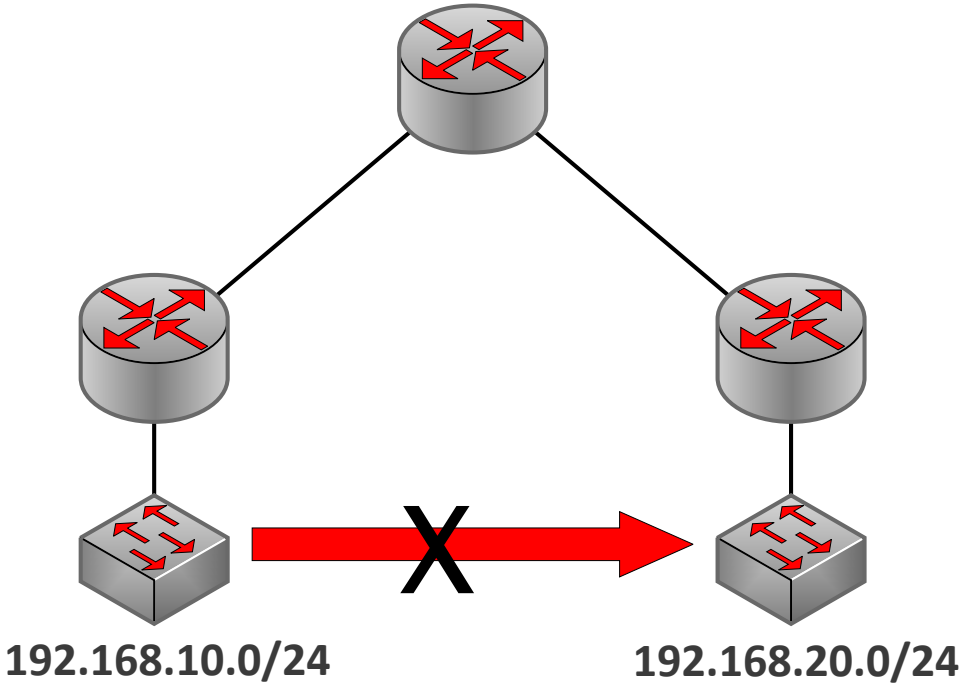
```
R1#show run | include access-list 5
access-list 5 deny 192.168.10.0 0.0.0.255
access-list 5 deny 192.168.20.0 0.0.0.255
access-list 5 deny 192.168.30.0 0.0.0.255
access-list 5 deny 192.168.40.0 0.0.0.255
```

Standard vs. Extended ACL

- **Standard ACL**
  - Filtrerar endast på source-adress
  - Nummer 1-99 (samt 1300-1999)
  - Exempel: **access-list 10 permit 192.168.10.0 0.0.0.255**
- **Extended ACL:**
  - Filtrerar på source & destination IP/port/protokoll
  - Nummer 100-199 (och 2000-2699)
  - Exempel: **access-list 103 permit tcp 192.168.10.0 0.0.0.255 any eq 80**

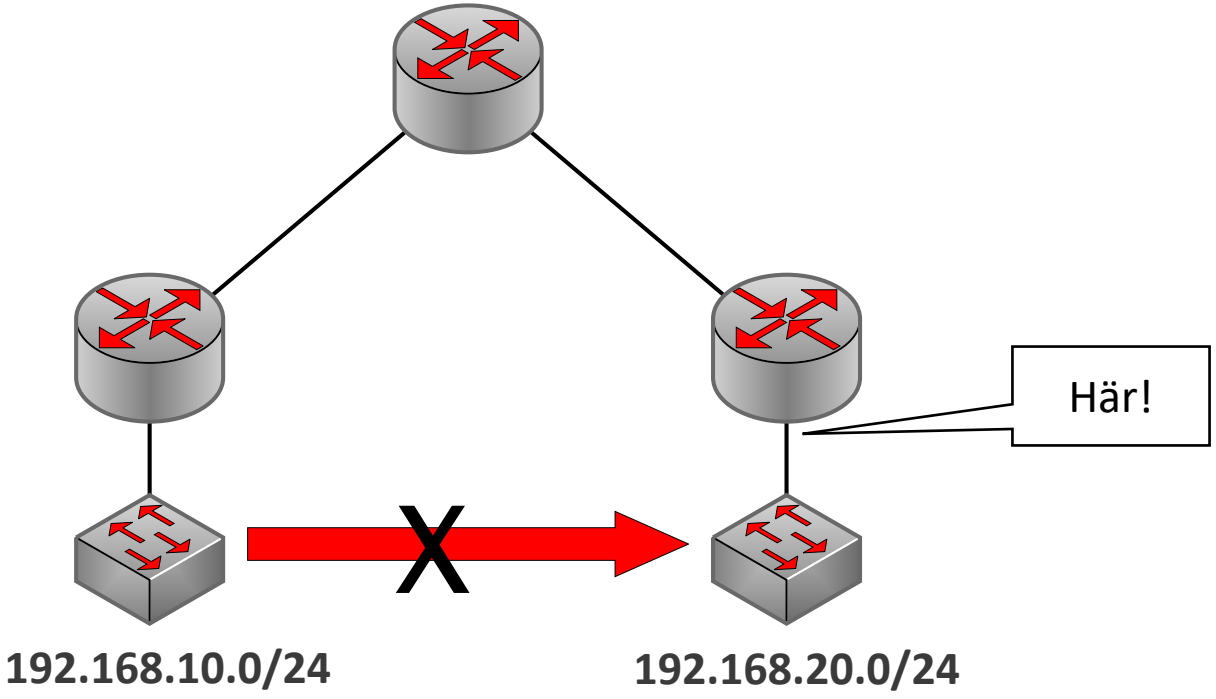
Var placeras en ACL?

- Vi vill blockera trafik från 192.168.10.0/24 att nå 192.168.20.0/24
- Var ska vi placera vår ACL?



Var placeras en standard ACL?

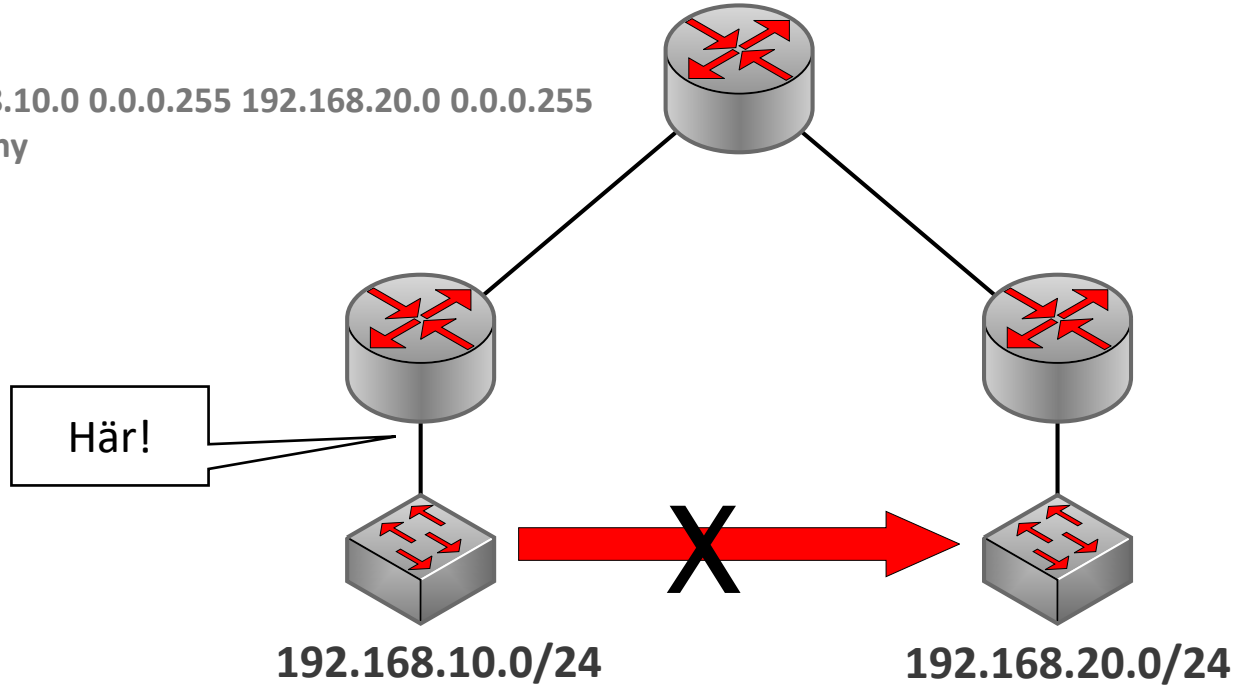
access-list 10 deny 192.168.10.0 0.0.0.255
access-list 10 permit any



Så nära målet som möjligt!

Var placeras en extended ACL?

```
access-list 101 deny ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255
access-list 101 permit ip any any
```

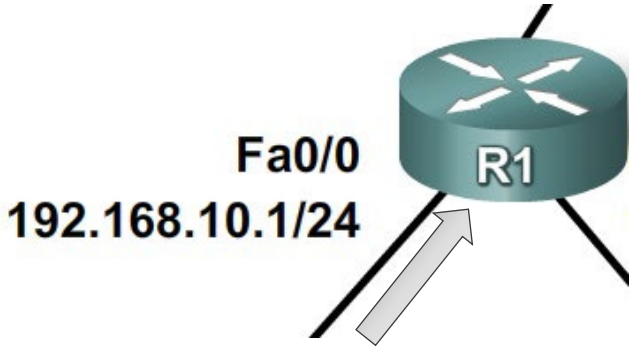


Så nära källan som möjligt!

Standard ACL

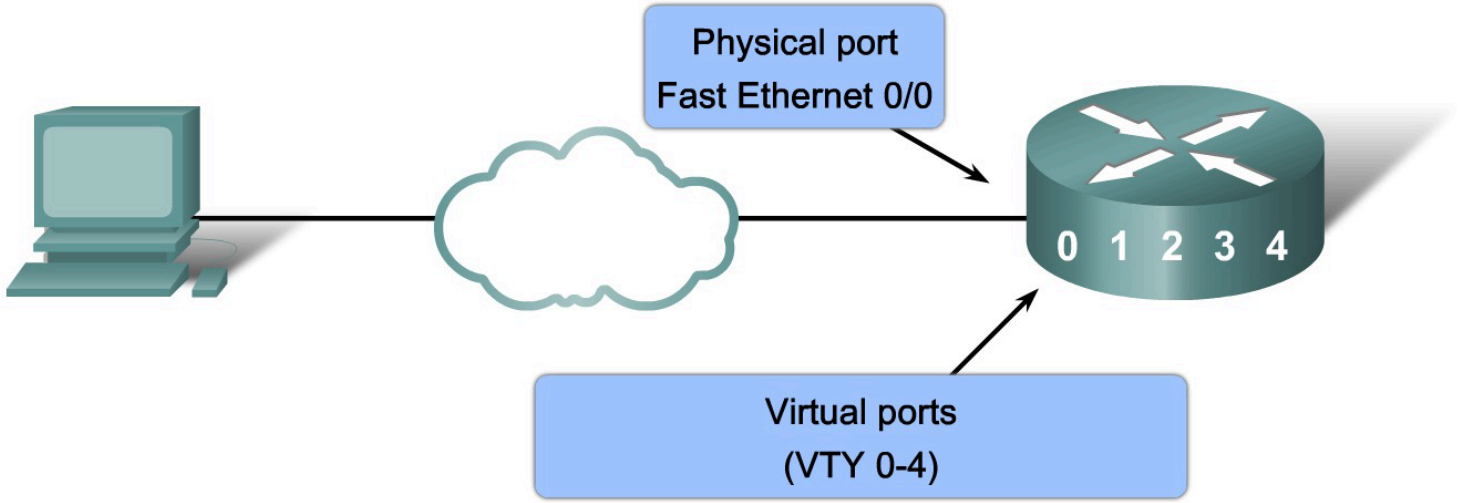
Tillämpa en ACL på interface

- Skapa en ACL
- Gå in på interfacet
- Applicera ACL på en interface tillsammans med riktning




```
R1(config)# access-list 10 permit 192.168.10.0 0.0.0.255
R1(config)# int fa0/0
R1(config-if)# ip access-group 10 in
```

Tillämpa ACL på VTY




```
R1(config)# access-list 21 permit 192.168.10.0 0.0.0.255
R1(config)# access-list 21 permit 192.168.11.0 0.0.0.255
R1(config)# access-list 21 deny any
R1(config)# line vty 0 4
R1(config-line)# login
R1(config-line)# password cisco
R1(config-line)# access-class 21 in
```

Redigera en ACL

- I numrerade ACLer går det inte att redigera en rad
  - **Lösning:** Ta bort ACLen helt och hållet och lägg till igen
- En rekommendation är att använda en textredigerare (exempel DNLAB)

```
R1(config)#access-list 10 permit …
R1(config)#access-list 10 permit …
R1(config)#access-list 10 permit …
R1(config)#no access-list 10
R1(config)#access-list 10 permit …
R1(config)#access-list 10 permit …
R1(config)#access-list 10 permit …
```

Namngivna ACLer (rekommenderas!)

- Kommando: **ip access-list standard *NAMN***

OBS!

```
R1(config)# ip access-list standard WEBBSERVER_BENGT
R1(config-std-nacl)# permit 193.10.31.160 0.0.1.255
R1(config-std-nacl)# permit 193.10.30.0 0.0.0.255
R1(config-std-nacl)# deny host 192.168.20.20
R1(config-std-nacl)# exit
R1(config)# interface fa0/0
R1(config-if)# ip access-group WEBBSERVER_BENGT out
```

Redigera namngivna ACLer

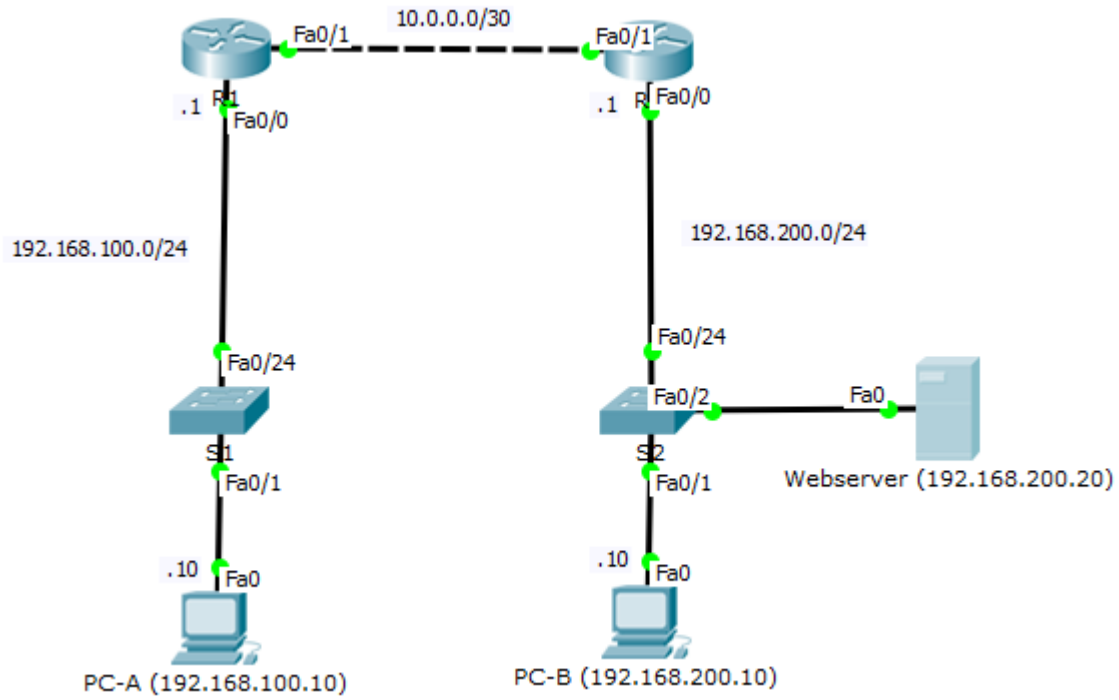
sekvensnummer

```
R1#show ip access-lists
Standard IP access list WEBBSERVER_BENGT
    10 permit 193.10.30.0 0.0.1.255
    20 permit 193.10.30.0 0.0.0.255
    30 deny host 192.168.20.20
```

```
R1(config)#ip access-list standard WEBBSERVER_BENGT
R1(config-std-nacl)#no 30
R1(config-std-nacl)#30 deny 192.168.20.0 0.0.0.255
R1(config-std-nacl)#
```

Livelabb – Packet Tracer

- IP-adressering är förberett
- Uppgift:
  - Tillåt 192.168.100.0/24 att använda Telnet till R2
  - Övrig trafik ska förbjudas
- Verifiera med **show access-lists**



Extended ACL

- Filterar på…
  - Source & destination IP (L3)
  - Source & destination port (L4)
- Placeras därför så nära källan som möjligt (för att spara på prestanda)
- **Livelabb:** Om tid finns

access-list 101	permit	tcp	192.168.0.0 0.0.0.255	host 193.10.31.167	eq 80
Namn 101 = extended ACL	**Action** permit/deny	**Protokoll** IP/TCP/UDP	**Source IP**	**Destination IP**	**Destination port**

kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering